

EECS 3482 A - Introduction to Computer Security

LAB 6 - Web Security

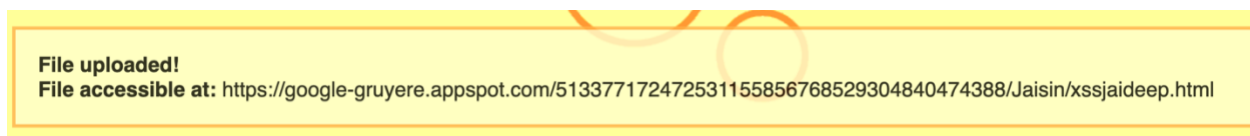
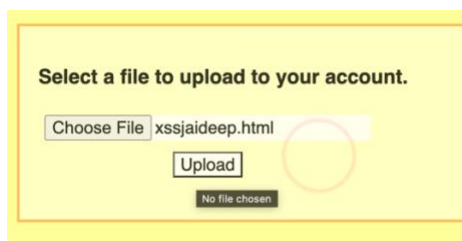
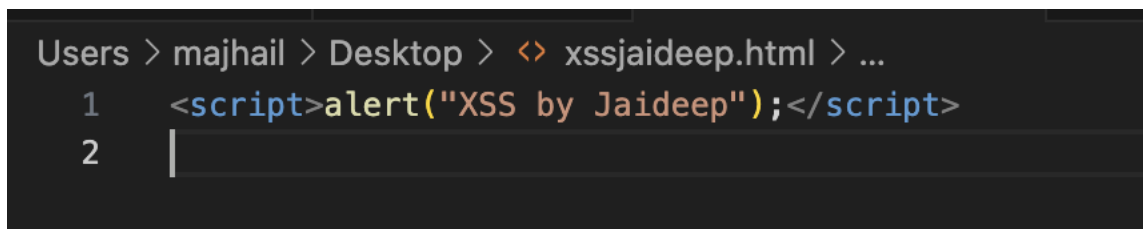
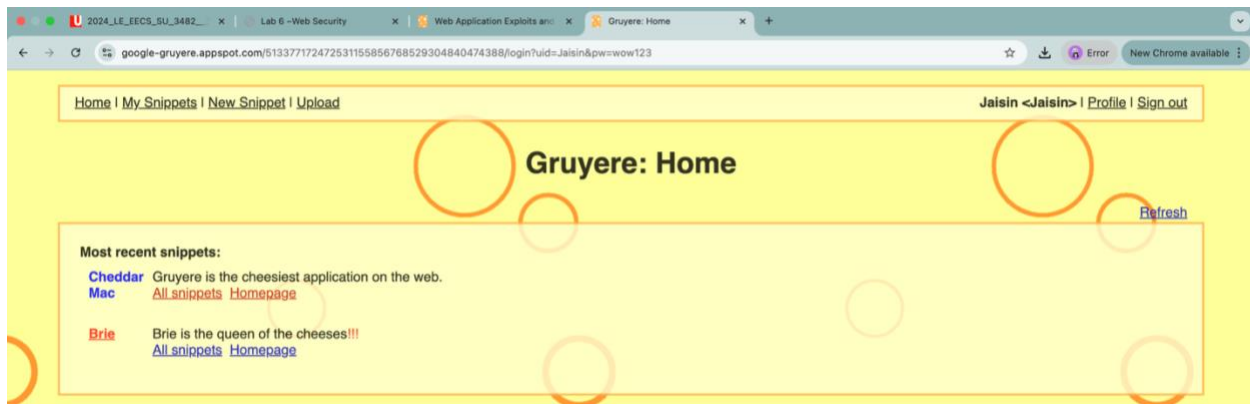
Submitted By- Jaideep Singh | Student ID – 218472241

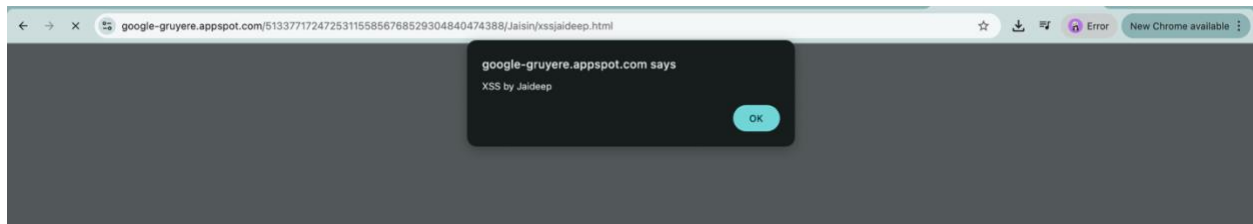
Part 1 - Experiment with the Gruyere platform

Link- <https://google-gruyere.appspot.com/513377172472531155856768529304840474388/>

Auto generated ID - 513377172472531155856768529304840474388

FILE UPLAOD XSS





Steps Taken:

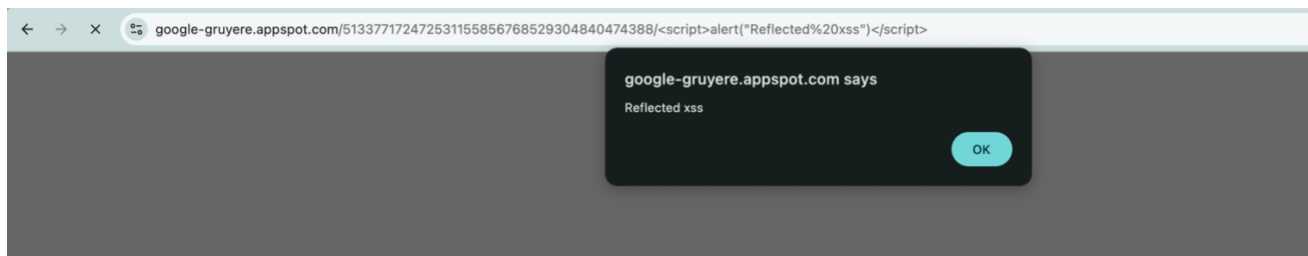
1. Created an HTML file named `xssjaideep.html` containing a script tag.
2. Logged into the Gruyere instance.
3. Navigated to 'Upload' and uploaded the file.
4. Accessed the file URL to verify script execution.

Payload Used: `<script>alert("XSS by Jaideep")</script>`

Result: Upon accessing the uploaded HTML file, a JavaScript alert popped up confirming script execution.

Proposed Countermeasure: Serve uploaded content as plain text or isolate user uploads on a sandboxed subdomain. Block HTML uploads or sanitize file contents.

Reflected XSS



Steps Taken:

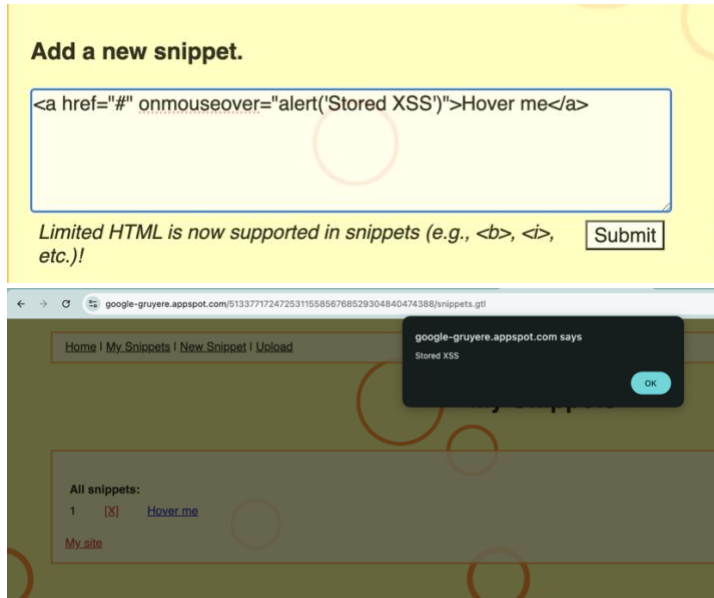
1. Logged into the instance.
2. Crafted a URL with an embedded script.
3. Pasted it into the browser and loaded the page.
4. Confirmed that the script was executed from the URL.

Payload Used : `<script>alert("Reflected xss")</script>`

Result : The browser executed the script in the URL and displayed an alert popup.

Proposed Countermeasure : Escape all user input reflected in output. Apply strict encoding and use a secure templating engine with output escaping.

STORED XSS



Steps Taken:

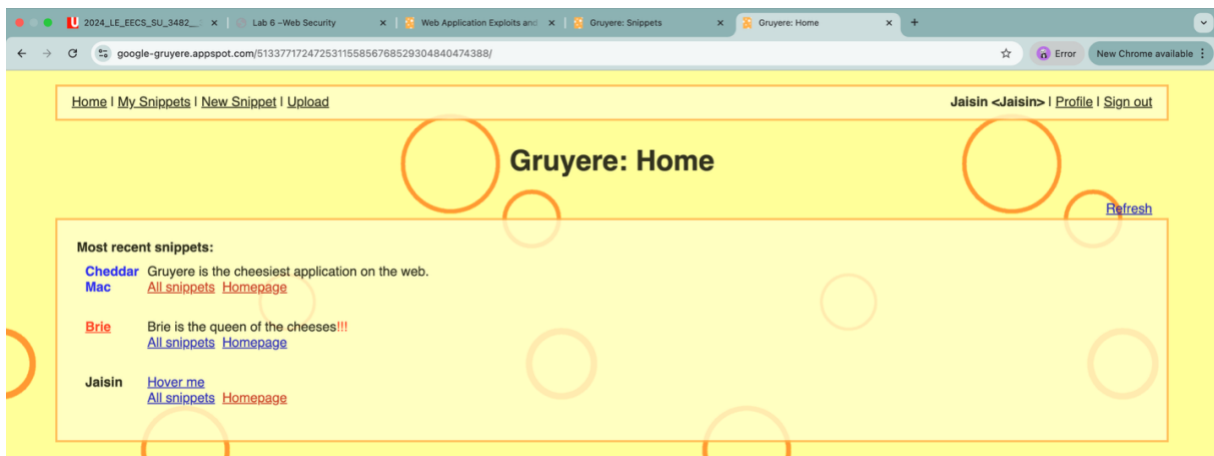
1. Navigated to 'New Snippet' while logged in.
2. Entered an anchor tag with an onmouseover event in the input box.
3. Saved the snippet and hovered over it to trigger the alert.

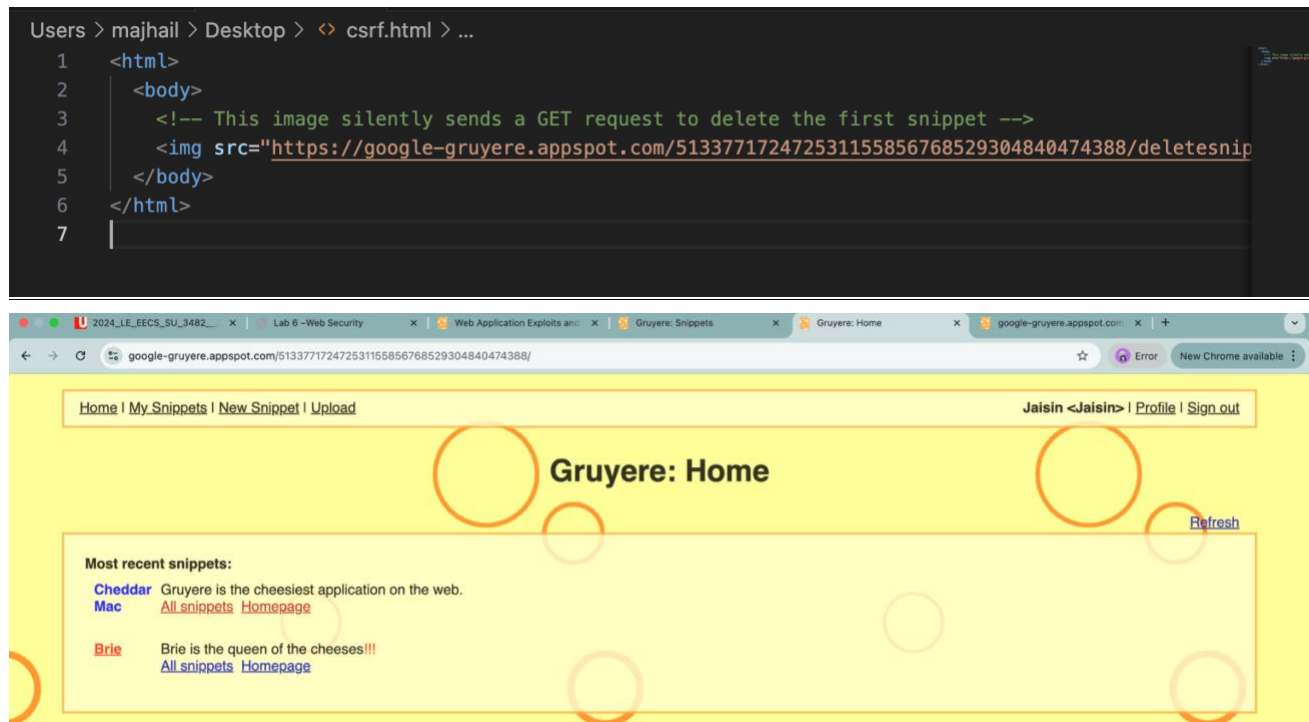
Payload Used: `<a href="#" onmouseover='alert("Stored XSS")>Hover me</a>`

Result: An alert executed when hovering over the link stored in a snippet.

Proposed Countermeasure: Use a whitelist-based HTML sanitizer like DOMPurify. Normalize tags and attributes to avoid bypasses.

CSRF





Steps Taken:

1. Created a file `csrf.html` with an image tag pointing to the deletion endpoint.
2. Opened the HTML file while logged in.
3. The request was sent and the snippet was deleted.

Payload Used: ``

Result: Snippet at index 0 was deleted silently when the CSRF HTML was opened.

Proposed Countermeasure: Require POST requests for deletions, include anti-CSRF tokens, and use SameSite cookie attributes.

Part 2 – Thought Experiment

Q- Are you still ethically accountable or professionally responsible for having helped build that system, even though you followed best practices at the time?

Answer: Even though retina scanning initially appeared secure and followed best practices, the irreversible nature of biometric data creates lasting ethical concerns. Unlike passwords, users cannot reset their retina or DNA, meaning developers bear long-term accountability that extends beyond their tenure at a company. Following best practices at the time does not absolve ethical responsibility when the system later causes irreparable harm.

Q- What long-term obligations do developers and engineers have to users when working with immutable data like biometrics?

Answer: Developers must:

- Anticipate breaches and design systems with strong fallback mechanisms (e.g., multi-factor authentication).
- Avoid storing raw biometric data—instead, use encrypted templates and decentralized storage to minimize damage from leaks.
- Advocate for privacy-by-design both during and after employment.
- Ensure transparency, making users fully aware of the permanent risks before obtaining consent.

Q- Should certain types of data never be used for authentication at all?

Answer: Certain data types must be excluded from authentication due to their irreversible risks:

- High-immutability biometrics (retina scans, DNA) cannot be changed if compromised.
- Coercive or invasive data (facial recognition, brainwave patterns) pose extreme privacy and dignity threats.
- Core Principle: If data cannot be revoked or protected indefinitely, it should never be used for authentication—convenience must never override ethical responsibility.